17 million potential customers who may benefit from this provision.[767] While we do not have data on the exact geographical distribution of customers across all covered institutions, we are able to identify registered investment advisers whose customers reside exclusively in GLBA Safe Harbor states.[768] We estimate that there are 679 such advisers, representing 4.4 percent of the registered adviser population, and that these advisers represent in total more than 97,000 clients.[769] We expect that a similar percentage of broker-dealers would be found to be operating exclusively in GLBA Safe Harbor states.

Changing the effect of the GLBA Safe Harbors is not likely to impose significant direct compliance costs on most covered institutions. For the reasons outlined above, many covered institutions have customers residing in states without a GLBA Safe Harbor and we therefore expect them to have existing procedures for notifying customers under state law. Additionally, some jurisdictions require notification policies or actual notification as condition of the safe harbor.[770] However, covered institutions whose customer base is limited to GLBA Safe Harbor states may not have implemented any procedures to notify customers in the event of a data breach. These covered institutions may face higher costs than entities with some notification procedures already in place, but the customers of these institutions will benefit the most from the final amendments by receiving notice they may not have otherwise received.

---

have exceptions for compliance with a primary Federal regulator, as discussed *supra*.

767 Estimates of the numbers of potential customers are based on state population adjusted by the percentage of households reporting direct stock ownership (21%). *See* U.S. CENSUS BUREAU, APPORTIONMENT REPORT (2020)*, available at* https://www2.census.gov/programs-surveys/decennial/2020/data/apportionment/apportionment-2020-table01.xlsx (last visited Apr. 12, 2024); *see also* Federal Reserve Board*, Survey of Consumer Finances* (2022), *available at* https://www.federalreserve.gov/econres/scfindex.htm (last visited Apr. 9, 2024).

768 Based on Form ADV, Item 2.C as of Oct. 5, 2023*; see also supra* footnote 655.

769 Based on Form ADV, Item 5.D as of Oct. 5, 2023; *see also supra* footnote 650.

770 *See, e.g.*, D.C. Code § 28-3852(g).

One commenter agreed that some state laws provided exemptions from their notice requirements under the GLBA but disagreed that this implied benefits for the amendments, stating that the proposed amendments would not preempt state notification requirements and would instead add another variation on existing requirements to be accounted for by covered institutions, with limited real benefits to affected individuals.[771] The final amendments will create new and to various extents different notification requirements for covered institutions with customers residing in states without GLBA exemptions. However, we disagree with this commenter's assertion that benefits to affected individuals will be limited. As discussed above, state laws vary in detail from state to state.[772] We discuss below how the final amendments will impose a Federal minimum standard for customer notification and how we expect this standard to benefit customers.

(2) Accelerated Timing of Customer Notification

The final amendments require covered institutions to provide notice to customers in the event of some data breaches as soon as practicable, but not later than 30 days, after becoming aware that unauthorized access to or use of customer information has occurred or is reasonably likely to have occurred.[773] As discussed in section IV.C.2.a, existing state laws vary in terms of notification timing. Most states (31) do not include a specific deadline for notifying customers, but rather require that the notice be given in an expedient manner and/or that it be provided

---

[771] *See* CAI Comment Letter ("Although some state laws do provide exemptions from their state specific notice requirements where a notice is provided consistent with requirements under the Gramm-Leach Bliley Act (GLBA), most do not. This proposed new requirement would not serve to preempt those generally applicable state notice requirements, and would not establish a new singular standard. It would just be another variation on existing requirements to be accounted for, with limited real benefit to affected individuals.").

[772] *See supra* section IV.C.2.a.

[773] *See* final rule 248.30(a)(4)(iii).

without unreasonable delay. These states account for 60 percent of the U.S. population, with approximately 42 million potential customers residing in these states.[774] Four states have a 30-day deadline; we estimate that close to 8 million potential customers reside in these states. The remaining 16 states provide for longer notification deadlines. For the estimated 20 million potential customers residing in these 16 states, the final amendments' 30-day outside timeframe might tighten the notification timeframes.[775] In addition, the 30-day outside timeframe is likely to tighten notification timeframes for the approximately 42 million potential customers residing in states with no specific deadline.

Even though the timing language in state laws without specific deadlines generally suggests that notices must be prompt, we have evidence that the notices are frequently sent significantly later than 30 days after the affected institution learns of the breach. The Proposing Release references data from California and Washington, which we explain in more detail below. California requires that such notice be given "in the most expedient time possible and without unreasonable delay."[776] Nevertheless, data from the California Office of the Attorney General, regarding notices sent to more than 500 California residents for any one incident, indicate that for the notices for which these data are available, the average time from discovery to notification was 144 days in 2022, and 91 percent of these notices were sent later than 30 days after the discovery of the breach.[777] Hence, we expect that the aggregate effects of a 30-day notification

---

774 *See supra* Figure 2; *see also supra* footnote 767.

775 State deadlines are either 30, 45, or 60 days, but differ in terms of triggers of those deadlines; s*ee supra* Figure 3.

776 *See* Cal. Civil Code § 1798.82.

777 This analysis was performed using data from the State of California Department of Justice, Office of the Attorney General, *Search Data Security Breaches* (2023), *available at* https://oag.ca.gov/privacy/databreach/list (last visited Apr. 8, 2024). California law requires that a sample copy of a breach notice sent to more than 500 California residents be provided to the California Attorney General. Four-hundred fifty-six such notices were reported in the year of 2022. Of those notices, 164 (36%)

outside timeframe might be significant for the 42 million potential customers residing in states with no specific deadline.[778]

In addition, because the final amendments will not provide for broad exceptions to the 30-day notification requirement,[779] in many cases the amendments will tighten notification timeframes even for the 8 million potential customers residing in states with a 30-day deadline. For example, in Washington, the state law requires that the notice be given "without unreasonable delay, and no more than thirty calendar days after the breach was discovered."[780] However, the law also allows for a delay "at the request of law enforcement" or "due to any measures necessary to determine the scope of the breach and restore the reasonable integrity of the data system."[781] Data from the Washington Attorney General's Office indicate that for the notices for which these data are available, the average time from discovery to notification was 137 days in 2022 and the median time was 93 days.[782] Eighty-seven percent of these notices

---

included both the date of the discovery of the breach and the date the notice was sent to affected individuals. For those 164 notices, the average number of days between discovery and notice was 144 and the median number of days was 107. One hundred fifty of these notices (91%) were sent more than 30 days after discovery. The minimum number of days was 0 and the maximum was 538. The Proposing Release cited an average number of days between discovery and notice of 197 (for calendar year 2021). The correct number should be 97. This change would not have affected the Commission's assessment, in the Proposing Release, that there would be substantial economic benefits from a new notification deadline in an amended Regulation S-P, as both estimates are substantially larger than 30 days.

778 The final amendments' 30-day notification timeframe starts when a covered institution becomes aware that unauthorized access to or use of customer information has occurred or is likely to have occurred. *See* final rule 248.30(a)(4)(iii). The analysis performed here relies instead on an entity's description of when it discovered or became aware of a breach, which could refer to a different point in time.

779 *See supra* footnote 544 and accompanying text.

780 *See* RCW 19.255.010(8).

781 *See* RCW 19.255.010(8).

782 This analysis was performed using data from the Washington State Office of the Attorney General, *Data Breach Notifications*, *available at* https://www.atg.wa.gov/data-breach-notifications (last visited Apr. 8, 2024). Washington law requires that any business, individual, or public agency that is required to issue a security breach notification to more than 500 Washington residents as a result of a single security breach shall electronically submit a single sample copy of that security breach notification. One hundred and eighty-five such notices were reported in the year 2022. For 121 (65%) of those notices, data is available for both the date of the discovery of the breach and the date the notice was sent to affected individuals. For

were sent later than 30 days after the discovery of the breach, presumably as a result of these exceptions.[783] Hence, we expect that the timing requirements of the final amendments will result in many notices being sent earlier even in some states with a 30-day deadline.

Tighter notification deadlines should increase customers' ability to take effective measures to counter threats resulting from their sensitive information being compromised. Such measures may include placing holds on credit reports or engaging in more active monitoring of account and credit report activity.

In practice, however, when it takes a long time to discover a data breach, a relatively short delay between discovery and customer notification may have little impact on customers' ability to take effective countermeasures.[784] Based on the data from the California Office of the Attorney General, the average number of days between the start of a breach and its discovery was 46 days in 2022, with a median of 7 days and a standard deviation of 126 days.[785] In addition, data from the Washington Attorney General's Office show that in 2022, there were on average 94 days between the time a breach occurred and its discovery, with a median of 10 days

---

those 121 notices, the average number of days between discovery and notice was 137 and the median number of days was 93. One hundred four notices (87%) were sent more than 30 days after discovery. The minimum number of days was 4 and the maximum was 651.

783 These numbers should be interpreted with care, since what different firms describe as the time at which they "discover" a breach could vary. *See also supra* footnote 778.

784 In other words, the utility of a notice is likely to exhibit decay. For example, if a breach is discovered immediately, the utility of receiving a notification within 1 day is considerably greater than the utility of receiving a notification in 30 days. However, if a breach is discovered only after 200 days, the difference in expected utility from receiving a notification on day 201 versus day 231 is smaller: with each passing day some opportunities to prevent the compromised information from being exploited are lost (e.g., unauthorized wire transfer), with each passing day opportunities to discover the compromise grow (e.g., noticing an unauthorized transaction), and with each passing day the compromised information becomes less valuable (e.g., passwords, account numbers, addresses, etc., generally change over time).

785 *See supra* footnote 777 describing the methodology. Many breaches, for example in the case of ransomware attacks or compromises of physical equipment, are discovered on the day that they happen or shortly thereafter.

and a standard deviation of 319 days.[786] This suggests that time to discovery is likely to prevent issuance of timely customer notices in many but not all cases. As plotted in Figure 9, while some firms take many months—even years—to discover a data breach, others do so in a matter of days: 66 percent of firms were able to detect a breach within 2 weeks and 77 percent were able to do so within 30 days.[787] Thus, while the adopted 30-day notification outside timeframe may not always substantially improve the timeliness of customer notices, in many cases it may improve timeliness.

---

[786] *See supra* footnote 782 describing the methodology. A few factors could influence the estimated length of time between a breach and its discovery by the notifying entity. First, the two states discussed here (California and Washington) require firms to report the date on which the breach started. In instances where firms do not know this information, they could report the discovery date instead. This would result in an underestimate of the time between when a breach occurs and its discovery. Second, as discussed above, different firms could interpret the meaning of discovery differently. *See supra* footnote 783. Third, the discovery date used for this estimate is the date on which the notifying entity discovers the breach. If the breach happened at a service provider, it is possible that the service provider discovered the breach earlier and notified its client later. Hence, the numbers reported here likely overestimate the amount of time the affected entity took to discover the breach when the breach affected an entity different from the notifying entity. For comparison, according to IBM, in 2023 it took an average of 207 days to identify a data breach. *See* 2023 IBM Cost of Data Breach Report.

[787] Based on data from the State of California Department of Justice, Office of the Attorney General. *See supra* footnote 777; footnote 785 and accompanying text. The equivalent numbers for Washington are 56% and 73%, based on data from the Washington State Office of the Attorney General. *See supra* footnote 782; footnote 786 and accompanying text.

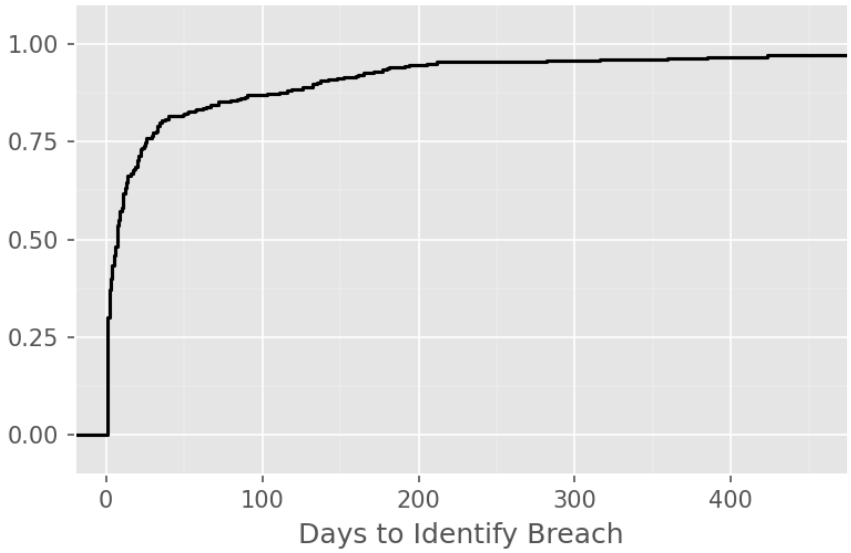

Figure 9: Cumulative distribution of the number of days between a breach and its discovery based on breaches reported in California in 2022. Data source: State of California Department of Justice, Office of Attorney General.

While we do not expect that the 30-day outside timeframe for customer notification will impose significant direct costs relative to a longer timeframe (or relative to having no fixed timeframe), the shorter outside timeframe might potentially lead to indirect costs arising from notification potentially interfering with incident containment efforts. Based on data from the Washington Attorney General's Office for the fiscal year of 2022, "containment" of data breaches generally occurs quickly—7.6 days on average.[788] However, according to IBM's study for 2022, it takes an average of 70 days to "contain" a data breach.[789] The discrepancy suggests

[788] In the data provided by the Washington Attorney General, "containment" (data field *DaysToContainBreach*) is defined as "the total number of days it takes a notifying entity to end the exposure of consumer data, after discovering the breach." *See supra* footnote 782.

[789] In the IBM study, "containment" refers to "the time it takes for an organization to resolve a situation once it has been detected and ultimately restore service." *See* 2022 IBM Cost of Data Breach Report. We use the 2022 average here (70 days) to align with the date of the Washington and California state data, but note that IBM reports for 2021 and 2023 reported averages of 75 and 73 days, respectively. *See* Proposing Release at n.466; 2023 IBM Cost of Data Breach Report. Some of the discrepancy may be due to variation in how entities report the date at which the breach started in the data for Washington; *see supra* footnote 786.

that there exists some ambiguity in the interpretation of "containment," raising the possibility that the 30-day notification outside timeframe might require customer notification to occur before some aspects of incident containment have been completed and potentially interfering with efforts to do so.[790]

Some commenters opposed the proposed timeframe for customer notifications.[791] One commenter stated that the proposed outside timeframe of 30 days after becoming aware of a breach was insufficient time to provide a meaningful notification to impacted individuals, particularly in complex cases.[792] Another commenter stated that the proposed 30-day outside timeframe was "unjustified and arbitrary" and that it was "likely to be insufficient for proper investigation and notification."[793] Another commenter stated that the proposed timing requirement was overly rigid and did not account for the wide variety and complexity of cybersecurity incidents, and that 30 days after becoming aware of a possible incident was not enough time to accomplish the many steps required to be able to issue notifications to affected individuals.[794] This commenter detailed these steps as "needing to respond to and remediate the security incident directly, conduct a forensic investigation to determine what information may have been affected, analyze the affected data to determine what sensitive customer information is contained in affected data, extract or obtain the information needed to make notification to affected users, hire vendors and arrange identity protection services for affected individuals, and

---

790 For example, the notice may prompt the attacker to accelerate efforts to obtain or use sensitive information before the vulnerability can be completely contained.

791 *See, e.g.*, ACLI Comment Letter; IAA Comment Letter 1.

792 *See* ACLI Comment Letter. *See also* Cambridge Comment Letter; IAA Comment Letter 1.

793 *See* Federated Comment Letter.

794 *See* CAI Comment Letter.

actually send the notifications."[795] These commenters, as well as other commenters, suggested longer or less specific timeframes.[796]

A different commenter instead stated that the final required timeframe should not be longer than 30 days, citing an article stating that "an analysis of the current state data breach notification laws shows that requiring notification within thirty days of a breach to affected consumers would be appropriate."[797] This article further adds that a "thirty-day time limit will give an organization ample time to conduct a full investigation" and "ensure that consumers are notified of a breach in a timely manner so they can take the proper steps to mitigate any losses and protect their personal information from further exposure to cybercriminals through credit freezes, credit monitoring, and the like." The same commenter suggested that the deadline be shortened to 14 days after becoming aware of an incident.[798]

After considering these comments, we are adopting the notification timeframe as proposed. Under the final amendments, covered institutions will be required to provide notice to affected customers as soon as practicable, but not later than 30 days, after becoming aware that unauthorized access to or use of customer information has occurred or is reasonably likely to have occurred. Commenters stated that this notification timeframe may result in customers

---

795 *See* CAI Comment Letter.

796 *See, e.g.*, FSI Comment Letter ("We recommend that the notification requirement under Reg S-P be revised from 'as soon as practicable, but not later than 30-days' to 'as soon as practicable, but not later than 60-days' after a firm becomes aware that unauthorized access to or use of customer information has occurred or is reasonably likely to occur."); Cambridge Comment Letter ("A period of, for example, 60 days would be more realistic, while achieving the Proposals' same goals."); IAA Comment Letter 1 ("We recommend a 45-day rather than a 30-day notification requirement to provide a more reasonable amount of time for advisers to perform investigation and risk assessments, collect the information necessary to include in client notices, and provide notices in complex cases.").

797 *See* Better Markets Comment Letter, citing Gregory S. Gaglione Jr., *The Equifax Data Breach: An Opportunity to Improve Consumer Protection and Cybersecurity Efforts in America*, 67 Buff. L. Rev. 1133 (2019).

798 *See* Better Markets Comment Letter.

receiving notices that are less accurate or receiving some notices that are unnecessary. The final amendments' notification timeframe may, in some cases, result in customers receiving less informative notices than they would have received under a longer notification timeframe, since covered institutions will have less time to understand the incident before sending the notice. This 30-day timeframe may also result in instances where a notification will be sent but, had the covered institution been able to fully investigate the breach in the prescribed timeframe, the covered institution would have been able to determine that notification was not required.[799] If unnecessary notifications are sent, as commenters suggest could occur, these instances may result in customers taking unnecessary mitigating actions, and the costs of these actions will be a cost of the final amendments.[800] These instances will also result in additional costs associated with customer notification, such as administrative costs related to preparing and distributing notices and potential reputational costs (including indirect costs of customer information protection improvements that may be undertaken to avoid such reputational costs) for covered institutions; we have accounted for these additional costs associated with notification in our estimates of some of the costs arising from notice issuance.[801] However, the 30-day notification timeframe preserves the benefits of the proposed, relatively short notification timeframe and allows customers to take rapid and effective mitigating actions.[802]

---

799 Longer investigations are likely to correlate with more complicated incidents and are less likely to result in a determination that notice is not required. We therefore do not expect that a longer notification outside timeframe would have led to significantly fewer required notices.

800 *See infra* section IV.D.1.b(4) for a discussion of the effect of unnecessary notification.

801 Certain costs arising from notice issuance are covered in the Paperwork Reduction Act analysis in section V and are estimated to be on average $5,178 per year per covered institution. This estimate is an annual average for the first three years. The corresponding ongoing annual costs beyond the first three years are estimated to be on average $3,862 per year per covered institution. *See infra* section V. We have increased these estimates from the proposal in response to commenters. *See infra* section V.

802 We have further reviewed, in response to commenters, evidence that customers prefer an early notification. A survey of U.S. individuals found that notifying customers immediately was one of main steps the